

Clase 286 — Concienciación y cultura de seguridad

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: (ISC)² CISSP Official Study Guide y SANS Security Awareness 🕒 Duración estimada: **80 min** · Nivel: **Fundamentos**

🎯 Objetivo

Comprender por qué el factor humano es el vector de ataque más explotado (phishing, ingeniería social, errores) y cómo construir un programa de concienciación y una cultura de seguridad que reduzca ese riesgo de forma medible. Al terminar sabrás diseñar campañas de formación, ejecutar simulaciones de phishing éticas, segmentar audiencias y medir el cambio de comportamiento, no solo la asistencia a un curso.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Diferenciar** concienciación, formación y educación.
2. **Diseñar** un programa de concienciación por audiencias y roles.
3. **Planificar** una simulación de phishing ética y sus métricas.
4. **Medir** el cambio de comportamiento (tasa de clics, de reporte).
5. **Fomentar** una cultura de seguridad positiva, sin culpabilizar.

📖 Temas

#	Tema	Por qué importa
1	El humano como superficie de ataque	La mayoría de brechas empiezan por una persona
2	Concienciación vs. formación vs. educación	Distintos objetivos y profundidad
3	Segmentación por rol y riesgo	No todos necesitan lo mismo
4	Simulaciones de phishing éticas	Practicar el reconocimiento real
5	Métricas de comportamiento	Clic, reporte, tiempo de detección
6	Cultura positiva vs. culpabilización	El miedo esconde incidentes
7	Refuerzo continuo	Un curso anual no cambia hábitos

📖 Definiciones y características

- **Concienciación (awareness)**: mantener la seguridad presente en la mente del usuario. *Clave*: cambia el foco de atención, es continua.
- **Formación (training)**: enseñar habilidades concretas para un rol. *Clave*: orientada a tareas.
- **Educación**: conocimiento profundo y transferible. *Clave*: forma expertos, largo plazo.

- **Simulación de phishing:** envío controlado de correos señuelo para medir y entrenar. *Clave:* educar, no castigar.
- **Tasa de clics (click rate):** porcentaje que interactúa con el señuelo. *Clave:* baja con la práctica; métrica de partida.
- **Tasa de reporte (report rate):** porcentaje que denuncia el phishing. *Clave:* es la métrica que de verdad importa; que suba.
- **Cultura de seguridad:** valores y comportamientos compartidos respecto a la seguridad. *Clave:* se mide y se cultiva, no se impone.

Herramientas y preparación

- Plataforma de simulación de phishing en laboratorio: *GoPhish* (open source, <https://getgophish.com/>), desplegado en un entorno de pruebas propio.
- Un servidor de correo de laboratorio o cuentas de prueba controladas (nunca envíes a terceros reales sin autorización).
- Material de concienciación de referencia: *SANS Security Awareness*, *CISA* y *NIST SP 800-50/800-16*.
- Hoja de cálculo para el plan de campañas y las métricas.

⚠ Las simulaciones de phishing se ejecutan **solo** sobre empleados de tu propia organización, con aprobación de dirección/RR. HH. y de forma ética. Nunca contra personas ajenas ni con señuelos abusivos.

Laboratorio guiado (ejercicio aplicado)

Parte A — Programa de concienciación para "Ferretería del Sur S.A.":

1. **Segmentación:** define 3 audiencias (personal general, desarrolladores, finanzas) y el riesgo principal de cada una (phishing genérico, seguridad en el código, fraude del CEO/BEC).
2. **Plan anual:** crea un calendario de 12 meses con temas mensuales (contraseñas, phishing, datos personales, escritorio limpio, incidentes) y formato (píldora, taller, cartel, simulación).
3. **Contenido:** redacta el guion de una píldora de 5 minutos sobre cómo reconocer un correo de phishing (remitente, urgencia, enlaces, adjuntos).

Parte B — Simulación de phishing ética (laboratorio con GoPhish):

4. Despliega GoPhish en tu VM de laboratorio y crea una campaña con: plantilla de correo señuelo, landing page de formación y grupo de "empleados de prueba" (cuentas propias).
5. Lanza la campaña contra tus cuentas de prueba y observa las métricas: enviados, abiertos, clics, datos enviados.
6. Diseña la **página educativa** que ve quien pica: explica qué señales debió detectar y cómo reportar en el futuro (sin humillar).

Parte C — Métricas y mejora:

7. Registra la tasa de clics y de reporte iniciales. Define el objetivo del próximo trimestre (bajar clics, subir reporte).
8. Redacta el mensaje de refuerzo positivo para quienes reportaron correctamente.

Ejercicios

1. Diferencia con ejemplos concienciación, formación y educación.
2. Diseña 3 señuelos de phishing de dificultad creciente (bajo, medio, dirigido/spear).
3. Explica por qué la tasa de reporte importa más que la de clics.
4. Propón cómo formarías específicamente al equipo de finanzas contra el fraude BEC.
5. Un empleado picó en la simulación. Redacta el mensaje que le enviarías sin culpabilizarlo.
6. Define 3 indicadores para medir la madurez de la cultura de seguridad.

Reto verificable

Entrega un **programa de concienciación** con: segmentación por 3 audiencias, calendario anual de temas, una simulación de phishing ejecutada en laboratorio (GoPhish) con métricas de clic y reporte, y la página educativa post-clic.

Criterio de aceptación: la campaña se ejecutó solo sobre cuentas de prueba propias, se registran tasas de clic y reporte iniciales con un objetivo de mejora, y el material educativo refuerza sin culpabilizar.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Un único curso anual "para cumplir"	No cambia hábitos; usa refuerzo continuo y variado
Simulaciones que humillan o castigan	Generan miedo y ocultación; enfoque educativo y positivo
Medir solo asistencia	No mide comportamiento; usa clic y reporte
Mismo contenido para todos	Ineficaz; segmenta por rol y riesgo
Enviar simulaciones a terceros sin permiso	Problema ético y legal; solo empleados propios con aprobación

Preguntas frecuentes

? ¿Sirven de algo las simulaciones de phishing? Sí, si son educativas y continuas: reducen la tasa de clics y —más importante— aumentan la de reporte. Usadas como castigo, son contraproducentes.

? ¿Cuál es la mejor métrica? La tasa de reporte. Que la gente reconozca y denuncie un phishing es más valioso que solo evitar el clic, porque activa la respuesta a incidentes.

? ¿Cómo consigo apoyo de la dirección? Traduciendo el riesgo humano a números (coste de una brecha por BEC) y midiendo la mejora del comportamiento tras el programa.

? ¿Cada cuánto formar? De forma continua: píldoras breves y frecuentes superan a un curso largo anual. La constancia crea hábito.

Referencias

- NIST SP 800-50 Rev.1 — Building a Cybersecurity Awareness Program.
<https://csrc.nist.gov/pubs/sp/800/50/r1/ipd>

- SANS Security Awareness. <https://www.sans.org/security-awareness-training/>
- GoPhish — Open-source phishing framework. <https://getgophish.com/>
- CISA — Phishing guidance. <https://www.cisa.gov/topics/cyber-threats-and-advisories/phishing>
- (ISC)² CISSP Official Study Guide, dominio 1.

Siguiente clase

Clase 287 - Métricas de seguridad: KPIs y KRIs